

# Dossier tecnico, sicurezza e valutazione d'impatto preliminare

## Sistema di prenotazione dello scarto librario

---

**Organizzazione:** Biblioteca statale Stelio Crise

**Applicazione:** Gestione Scarto Librario per WordPress

**Versione analizzata:** 9.4.4 candidata, schema database 8.15

**Data del documento:** 20 agosto 2026

**Pagina del servizio:** <https://bibliotecacrise.cultura.gov.it/scarto-librario/>

**Informativa:** <https://bibliotecacrise.cultura.gov.it/informativa-privacy-scarto-librario/>

# Indice

- |                                               |                                             |
|-----------------------------------------------|---------------------------------------------|
| 1. Sintesi esecutiva                          | 10. Destinatari e dipendenze                |
| 2. Ambito e metodo                            | 11. Threat model                            |
| 3. Finalità e interessati                     | 12. Valutazione preliminare dei rischi      |
| 4. Architettura tecnica                       | 13. Punti aperti per Titolare e RPD         |
| 5. Contratto dati e visibilità                | 14. Piano di miglioramento tecnico          |
| 6. Processi utente                            | 15. Storico sintetico del progetto          |
| 7. Processi amministrativi                    | 16. Evidenze da consegnare allo specialista |
| 8. Misure di sicurezza                        | 17. Approvazioni                            |
| 9. Conservazione, cancellazione e portabilità |                                             |

Questo documento costituisce un dossier tecnico e una base di lavoro per analisi dei rischi e DPIA. Non è una DPIA approvata, non sostituisce il parere del RPD/DPO e non certifica la sicurezza dell'intera infrastruttura WordPress, dell'hosting o dei sistemi di posta e protocollo.

## 1. Sintesi esecutiva

Il plugin pubblica il catalogo dei volumi destinati allo scarto e consente agli utenti di prenotarli tramite verifica dell'indirizzo email. Il personale opera dall'area amministrativa WordPress per importare il catalogo, creare prenotazioni in sede, confermare consegne, annullare richieste, inviare riepiloghi, generare PDF, consultare log e statistiche, gestire i diritti degli interessati e creare backup cifrati.

La versione analizzata utilizza capability WordPress dedicate, nonce REST, validazione degli input, query preparate, transazioni InnoDB, rate limiting, OTP temporanei, cifratura AES-256-GCM per le richieste pendenti e i backup, audit log e cleanup programmati. I dati personali non risultano pubblicati dalle API del catalogo e la password aggiuntiva del plugin è conservata come hash bcrypt, non in chiaro.

I principali rischi residui riguardano la sicurezza complessiva del sito WordPress, l'enumerazione pubblica di profili utente, XML-RPC, account amministrativi senza secondo fattore, configurazione WAF/proxy, copie ed esportazioni fuori dal plugin, dipendenza dal recapito email e decisioni organizzative ancora da approvare su base giuridica, retention, blacklist e richieste di cancellazione. La 2FA non è prevista nell'attuale piano operativo; la sua assenza deve essere formalmente accettata come rischio temporaneo.

## 2. Ambito e metodo

L'analisi comprende sorgenti PHP, React/TypeScript, schema REST, tabelle, ruoli, log, strumenti privacy, importazione Excel, backup e pacchetto candidato 9.4.4. Sono stati considerati anche controlli HTTP passivi sul sito pubblico, che al momento della verifica eseguiva una baseline precedente. Non sono stati eseguiti exploit, scansioni invasive, accessi autenticati di produzione, revisione del sistema operativo, del database gestito, del server SMTP, dei contratti con i fornitori o del codice di tema e plugin terzi.

Evidenze automatiche disponibili alla data del documento:

- sintassi PHP: superata;
- controllo statico di sicurezza del repository: superato;
- TypeScript e build Vite: superati nell'ultimo ciclo di rilascio;
- `npm audit` sulle dipendenze di produzione: zero vulnerabilità note rilevate;
- test PHP offline backup: superati per prenotazione online, prenotazione in sede senza email, cifratura, password errata e alterazione;
- verifica ZIP offline: due build identiche, 40 file dichiarati e checksum interni validi;
- controlli passivi: HTTPS e HSTS attivi, `.env`, `.git` e `debug.log` non esposti;
- elementi da correggere: profili WordPress enumerabili, XML-RPC attivo, `readme.html` pubblico e protezioni server migliorabili.

## 3. Finalita e interessati

---

Documento interno di lavoro - 20/08/2026

### 3.1 Finalita operative

- rendere consultabile il catalogo dei volumi disponibili per lo scarto;
- acquisire e verificare prenotazioni online;
- registrare prenotazioni ricevute in sede;
- impedire prenotazioni concorrenti dello stesso volume;
- comunicare codice, riepilogo e stato della prenotazione;
- supportare ricerca fisica, consegna e produzione del documento di ritiro;
- prevenire abusi, ricostruire operazioni e produrre statistiche aggregate;
- consentire export, rettifica, limitazione, cancellazione o anonimizzazione;
- garantire continuit  tramite backup e ripristino.

### 3.2 Categorie di interessati

- utenti che effettuano o tentano una prenotazione online;
- utenti assistiti dal personale presso la biblioteca;
- personale e amministratori WordPress identificati nei log;
- soggetti inseriti in blacklist o sottoposti a limitazione del trattamento.

Il RPD deve confermare finalita, base giuridica, necessita e proporzionalita. La casella frontend attesta la presa visione dell'informativa e non deve essere descritta come consenso revocabile se il trattamento si fonda su compito di interesse pubblico.

## 4. Architettura tecnica

---

### 4.1 Componenti

- WordPress fornisce autenticazione, ruoli, nonce, cron, posta, opzioni e database `$wpdb`.
- `gestione-scarto-librario.php` contiene bootstrap, schema, migrazioni, dominio, REST, OTP e lifecycle.
- `includes/security.php` contiene controlli origine, payload, sessione, capability, nonce e cache privata.
- `includes/rest-schema.php` definisce contratti, limiti e allowlist dei payload REST.
- `includes/admin.php` registra menu, ruoli, impostazioni e strumenti interessati.
- `includes/audit-admin.php` gestisce log, filtri, CSV e statistiche.
- `includes/data-tools.php` gestisce backup cifrato e ripristino transazionale.
- `includes/gdpr-privacy-policy.php` rende l'informativa mediante shortcode.
- `src/index.tsx` e `src/index.css` sono le sorgenti frontend; Vite genera bundle separati in `dist/`.
- `templates/app.php` rende la pagina pubblica e applica intestazioni di sicurezza.

## 4.2 Schema dei flussi

Documento interno di lavoro · 20/08/2026

### Visitatore HTTPS

```
|
+--> Pagina WordPress + bundle pubblico
|
|
|   +--> REST pubblico: catalogo/ricerca/disponibilita
|   +--> POST prenotazione -> rate limit -> OTP via wp_mail/SMTP
|   +--> conferma OTP -> transazione InnoDB -> ordine + volumi
|
```

### Personale autenticato WordPress

```
|
+--> wp-admin + bundle amministrativo
|
|   +--> capability + cookie WP + X-WP-Nonce + stessa origine
|   +--> prenotazioni/catalogo/impostazioni/log/statistiche
|   +--> operazioni critiche + password di sicurezza del plugin
|   +--> backup cifrato scaricato direttamente dal browser
```

### Database WordPress

```
+--> catalogo
+--> prenotazioni e righe volume
+--> OTP/payload temporanei cifrati
+--> token privacy temporanei con token hash
+--> contatori anti-abuso pseudonimizzati
+--> audit log e opzioni
```

## 4.3 Ambiente dichiarato

Il sito di destinazione è stato indicato con Linux/Apache, PHP 8.4.11, WordPress 7.0.4, MoneyFlow Child Theme ed Elementor 4.2.2. Il plugin dichiara WordPress minimo 6.6 e PHP minimo 8.2. Compatibilità con altri plugin, WAF, cache e SMTP deve essere verificata sul sito effettivo a ogni aggiornamento.

## 5. Contratto dati e visibilità

| Insieme      | Dati principali                                                                                        | Visibilità                                                       | Conservazione tecnica           |
|--------------|--------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|---------------------------------|
| Catalogo     | ID, inventario, autore, titolo, editore, anno, collocazione, conservazione, motivazioni, note, scatola | sottoinsieme pubblico; scatola e note operative riservate        | fino a sostituzione/reset       |
| Prenotazione | codice, request ID, stato, origine, date, nome, cognome, email o domicilio, versione                   | personale autorizzato e interessato tramite comunicazioni/export | secondo stato e piano approvato |

Sistema di prenotazioni informativo · v9.4.4 RC

| Insieme                                  | Dati principali                                                                                        | Visibilit                       | Conservazione<br>tecnica     |
|------------------------------------------|--------------------------------------------------------------------------------------------------------|---------------------------------|------------------------------|
| Documento interno di lavoro - 20/08/2026 |                                                                                                        |                                 |                              |
| Volumi prenotati                         | titolo, autore, inventario, scatola, stato, consegna                                                   | scatola riservata al personale  | collegata alla prenotazione  |
| OTP pendente                             | request ID, hash OTP, hash email, payload cifrato, tentativi, scadenza                                 | sistema                         | circa 15 minuti              |
| Richiesta privacy                        | email, hash token, azione, uso, scadenza                                                               | sistema/personale privacy       | circa 30 minuti, poi cleanup |
| Rate limit                               | HMAC della chiave tecnica, tentativi, scadenza                                                         | sistema                         | finestra anti-abuso          |
| Audit                                    | categoria, azione, esito, entita, email pertinente, utente WP, dettaglio ridotto, IP, User-Agent, data | capability privacy              | periodo log/IP approvato     |
| Blacklist                                | email, motivo sintetico, autore, inserimento, scadenza/riesame                                         | capability privacy              | fino a scadenza o riesame    |
| Limitazione                              | email, motivazione, termine, autore e data                                                             | capability privacy              | fino al termine/riesame      |
| Backup                                   | intero archivio applicativo e impostazioni                                                             | personale privacy; file cifrato | secondo procedura esterna    |

## 5.1 Prenotazione online

Sono richiesti nome, cognome, email, volumi selezionati e attestazione di presa visione. Il domicilio non viene accettato n  conservato nel percorso online. Il server rileva l'IP; il `User-Agent` e conservato soltanto negli audit log pertinenti. Il browser non viene sottoposto a fingerprinting e il plugin non integra pubblicit  o analytics propri.

## 5.2 Prenotazione in sede

Il personale inserisce nome e cognome. Se e disponibile un'email valida, il domicilio non e raccolto. Se l'interessato non dispone di email, devono essere indicati via/piazza, civico, CAP, citta e provincia; le note di spedizione sono facoltative e devono contenere solo indicazioni necessarie. Il recapito serve all'eventuale spedizione della lettera contenente il documento protocollato relativo alla prenotazione e alla consegna.

## 5.3 Dati pubblicati

Le API pubbliche espongono informazioni bibliografiche, inventario, stato di conservazione e disponibilit /countdown. Non espongono nome, email, domicilio, IP, User-Agent, codice prenotazione, numero di scatola, log, backup o diagnostica. Nomi e schemi delle route REST sono pubblicamente enumerabili per natura dell'API WordPress: non devono essere considerati segreti.

## 6. Processi utente

---

Documento interno di lavoro - 20/08/2026

### 6.1 Consultazione e prenotazione

1. L'utente consulta o ricerca il catalogo paginato.
2. Seleziona i volumi disponibili; la disponibilit  viene ricontrollata dal server.
3. Inserisce nome, cognome ed email e prende visione dell'informativa.
4. Il server valida i campi, verifica blacklist/limitazioni e applica limiti IP/email.
5. Viene generato un OTP numerico di sei cifre. Il payload pendente e cifrato e l'OTP e memorizzato solo come hash/HMAC.
6. L'utente inserisce l'OTP entro circa 15 minuti e con un massimo di tentativi.
7. Una transazione blocca e ricontrolla i libri, genera un codice univoco e crea la prenotazione in modo idempotente.
8. Il riepilogo viene inviato all'interessato e alla biblioteca secondo le impostazioni email.
9. I volumi restano riservati fino a consegna, annullamento o scadenza; il frontend mostra stato e countdown sincronizzato col server.

### 6.2 Diritti dell'interessato

Il percorso pubblico consente di richiedere export o cancellazione mediante controllo della casella email. La risposta iniziale e generica per ridurre l'enumerazione. Il token casuale e inviato per email, memorizzato come hash e scade. Le prenotazioni attive bloccano la cancellazione automatica; completate vengono anonimizzate e annullate/scadute eliminate secondo le regole correnti.

Questa automazione e una scelta tecnica, non una decisione giuridica. Il Titolare/RPD deve decidere se mantenere la cancellazione self-service o richiedere sempre verifica e autorizzazione del personale, considerando obblighi archivistici, protocollo, difesa di diritti e dati presenti in sistemi esterni.

## 7. Processi amministrativi

---

### 7.1 Ruoli

- **Operatore Scarto Librario:** visualizza e gestisce prenotazioni e crea richieste in sede.
- **Responsabile Scarto Librario:** possiede tutte le capability del plugin, incluse catalogo, impostazioni e privacy.
- **Amministratore WordPress:** riceve le capability del plugin.

L'accesso deve seguire minimo privilegio. Account nominali separati sono preferibili ad account condivisi; la disattivazione dell'account WordPress deve accompagnare cessazione o cambio mansione.

### 7.2 Operazioni principali

- **Importazione Excel** con validazione locale e server, limiti 10/20 MB secondo livello, massimo 50.000 righe, controllo duplicati e transazione;

- aggiornamento catalogo con conservazione delle prenotazioni e conferma rafforzata in presenza di richieste attive;

Documento interno di lavoro · 20/08/2026

- ricerca globale e paginata, filtro prenotazioni pendenti, conferma consegna, annullamento e reinvio riepilogo;
- creazione in sede senza OTP e senza limiti pubblici, sempre attribuita all'account WP;
- PDF di consegna con dati dei volumi e spazio firma;
- log filtrabili ed esportabili, statistiche aggregate ed esportazione CSV;
- gestione blacklist, whitelist istituzionale, retention e cleanup;
- ricerca interessato per email/codice, export JSON, rettifica, limitazione e cancellazione/anonimizzazione motivate;
- backup completo cifrato e ripristino sostitutivo validato.

Le operazioni critiche richiedono capability, nonce e password aggiuntiva. Questa è denominata nel codice storico "database password", ma non è la credenziale MySQL: è un segreto applicativo il cui hash bcrypt è memorizzato in `wp_options`.

## 8. Misure di sicurezza

### 8.1 Autenticazione e autorizzazione

- sessione WordPress e capability dedicate per ogni area;
- `X-WP-Nonce` per REST amministrative e nonce WordPress per form `admin-post`;
- verifica della stessa origine e `Content-Type: application/json`;
- password di sicurezza del plugin per import, reset, retention, privacy e backup;
- invalidazione delle sessioni applicative alla rotazione della password;
- cookie applicativo `Secure`, `HttpOnly`, `SameSite=Strict`, quando utilizzato.

### 8.2 Integrità e concorrenza

- tabelle operative InnoDB, transazioni e `SELECT ... FOR UPDATE`;
- `request_id` univoco e risposte idempotenti per doppio click/retry;
- codice prenotazione generato con sorgente crittografica e vincolo univoco;
- snapshot di disponibilità e ricontrollo server-side prima del commit;
- checksum, schema, dimensione e conteggi validati durante il ripristino.

### 8.3 Crittografia e segreti

- payload OTP cifrati AES-256-GCM con chiave derivata dai salt WordPress;
- OTP, recovery token e token privacy conservati come hash;
- password del plugin conservata come bcrypt cost 12;
- backup cifrati AES-256-GCM con chiave PBKDF2-HMAC-SHA256, salt e IV casuali;
- password MySQL gestita esclusivamente da WordPress in `wp-config.php` e non letta/esposta dal plugin;

- nessuna chiave SMTP o credenziale inclusa nel pacchetto esaminato.

Documento interno di lavoro · 20/08/2026

## 8.4 Sicurezza applicativa

- schemi REST con tipi, pattern, limiti e campi inattesi rifiutati;
- sanitizzazione e escaping contestuale WordPress;
- query dinamiche preparate o basate su identificatori interni in allowlist;
- limiti per dimensione richiesta, righe, paginazione, tentativi e frequenza;
- risposte private `no-store`; CSP, HSTS, `frame-ancestors`, `nosniff` e policy restrittive sulla pagina del servizio;
- asset e font locali, senza telemetria o CDN runtime del plugin;
- log privi di OTP, password, payload completi e domicilio nei dettagli liberi.

## 9. Conservazione, cancellazione e portabilità

I valori tecnici predefiniti sono 365 giorni per prenotazioni completate, 90 per annullate/scadute e audit, 30 per IP/User-Agent. Sono fallback e non devono essere considerati approvati. Il pannello richiede attestazione e password per modificarli. Il cron esegue scadenza prenotazioni, cleanup dati personali, anonimizzazione IP, eliminazione log, contatori e file temporanei e mostra data/conteggi dell'ultimo intervento.

Il reset elimina catalogo, prenotazioni, righe, OTP pendenti, token privacy e contatori, mantenendo impostazioni e audit necessari a documentare l'operazione. L'uninstall conserva i dati salvo opzione distruttiva esplicita. Il backup include catalogo, ordini, righe, log, blacklist, limitazioni e impostazioni; non include password, OTP, sessioni o contatori temporanei.

Il file scaricato, i PDF, le email, il protocollo e le copie cartacee escono dal perimetro tecnico del plugin e richiedono regole autonome su accesso, cifratura, trasmissione, conservazione e distruzione.

## 10. Destinatari e dipendenze

I dati possono essere trattati dal personale autorizzato, amministratori di sistema, fornitore hosting/database, gestore della posta e, quando applicabile, sistemi di protocollo e recapito. Il plugin usa `wp_mail` /PHPMailer e non garantisce consegna finale. Non sono previste dal codice analizzato comunicazioni a servizi pubblicitari o analitici.

Devono essere censiti contratti, nomine, localizzazione, subfornitori, trasferimenti extra SEE, log infrastrutturali, backup hosting e tempi di conservazione dei sistemi esterni. Anche tema, Elementor e altri plugin condividono processo PHP e privilegi WordPress e possono incidere sulla sicurezza complessiva.

## 11. Threat model

Documento interno di lavoro - 20/08/2026

### 11.1 Attori avversi o condizioni di rischio

- visitatore anonimo che automatizza richieste, enumera endpoint o tenta injection;
- utente che abusa di email altrui o prova OTP;
- bot che produce traffico e invii email;
- account Operatore, Responsabile o amministratore compromesso;
- insider autorizzato che consulta o esporta dati senza necessita;
- file Excel o backup manipolato;
- cache/CDN che memorizza risposte private;
- plugin/tema terzo vulnerabile nello stesso WordPress;
- errore operativo durante import, cleanup, modifica ruoli o hardening;
- compromissione server/database o furto di un backup scaricato.

### 11.2 Beni da proteggere

- dati identificativi, recapiti, IP/User-Agent e cronologia prenotazioni;
- codici prenotazione, OTP e token temporanei;
- catalogo e stato/disponibilita dei volumi;
- account, capability, nonce, salt WordPress e password aggiuntiva;
- log, blacklist, export, PDF e backup;
- disponibilita del servizio, integrita delle prenotazioni e reputazione email.

## 12. Valutazione preliminare dei rischi

Scala: probabilita e impatto da 1 (basso) a 5 (molto alto). Il rischio residuo e una stima tecnica da validare con Titolare, RPD e gestore infrastrutturale.

| Scenario                                                         | P/I iniziale | Controlli presenti                                                   | Residuo    | Trattamento richiesto                                                            |
|------------------------------------------------------------------|--------------|----------------------------------------------------------------------|------------|----------------------------------------------------------------------------------|
| Compromissione account admin                                     | 3/5          | password WP, capability, nonce, step-up distruttivo, audit           | medio-alto | password uniche, account nominali, alert login; 2FA rinviata e rischio accettato |
| Enumerazione profili WordPress                                   | 4/2          | nessun dato prenotazione esposto                                     | medio      | limitare endpoint o separare slug/display/login con regola antilockout           |
| Abuso OTP/email<br>Sistema di prenotazione dello scarto librario | 4/3          | limiti IP/email, blacklist, scadenza, risposta generica<br>v9.4.4 RC | medio      | WAF graduale, monitor SMTP e 429                                                 |
|                                                                  |              |                                                                      |            |                                                                                  |

| Scenario                        | P/I | Controlli presenti                                     | Residuo     | Trattamento richiesto                                                     |
|---------------------------------|-----|--------------------------------------------------------|-------------|---------------------------------------------------------------------------|
| iniziale                        |     | Documento interno di lavoro - 20/08/2026               |             |                                                                           |
| Accesso a REST amministrative   | 3/5 | capability, nonce, stessa origine, no-store            | basso-medio | completare copertura no-store anche sugli errori admin                    |
| Doppia prenotazione/concorrenza | 3/4 | lock InnoDB, transazione, vincoli univoci, idempotenza | basso       | test periodico concorrenza e storage InnoDB                               |
| Esfiltrazione database          | 2/5 | protezioni hosting, hash/cifratura temporanei          | medio       | hardening server, patching, minimo privilegio DB, backup hosting protetti |
| Furto backup/export/PDF         | 3/5 | backup cifrato e download auditato                     | medio       | archivio autorizzato, scadenza, canali sicuri, eliminare copie locali     |
| Import file ostile              | 3/4 | estensione/schema/limiti/sanitizzazione/transazione    | basso-medio | test file malevoli e mantenere libreria XLSX aggiornata                   |
| Cache di dati privati           | 2/4 | intestazioni no-store , CSP                            | basso-medio | aggiungere route admin mancanti al filtro e testare CDN                   |
| Uso improprio blacklist         | 3/4 | motivo breve, autore, scadenza/riesame, area privacy   | medio       | criteri approvati, informativa e riesame documentato                      |
| Retention errata o cron fermo   | 3/4 | cron, diagnostica e stato cleanup                      | medio       | cron di sistema, alert e verifica mensile                                 |
| Cancellazione non coordinata    | 3/4 | export/delete, blocco attive, audit                    | medio       | procedura Titolare/RPD e riconciliazione con email/protocollo/cartaceo    |
| Lockout da hardening            | 3/5 | accesso SFTP disponibile                               | basso-medio | applicare integralmente il gate antilockout                               |
| Vulnerabilit  tema/plugin terzi | 3/5 | aggiornamenti e hosting, non verificati qui            | medio-alto  | inventario, vulnerability scan e staging dell'intero sito                 |

Non sono emerse vie anonime semplici verso dati personali o password del plugin. Non   possibile escludere vulnerabilit  non note, compromissioni infrastrutturali o catene attraverso componenti terzi senza un penetration test autorizzato.

## 13. Punti aperti per Titolare e RPD

Sistema di prenotazione dello scarto librario - v9.4.4 RC

- confermare base giuridica e formulazione della presa visione;

- determinare se sia necessaria una DPIA formale ai sensi dell'art. 35;
- approvare retention e criteri di cancellazione per plugin, email, protocollo, lettere e backup;
- confermare necessita del domicilio solo in sede e senza email;
- approvare criteri, durata, informazione e riesame della blacklist;
- decidere se la cancellazione self-service possa produrre effetti automatici;
- definire verifica dell'identita, eccezioni e tempi per i diritti;
- identificare titolare, autorizzati, responsabili, amministratori di sistema e destinatari;
- censire log Apache/WAF/SMTP/hosting e trasferimenti;
- definire incident response, data breach e contatti di escalation;
- registrare la temporanea assenza di 2FA e le misure compensative.

## 14. Piano di miglioramento tecnico

La candidata 9.4.4 aggiunge alla precedente hardening il ripristino sicuro delle prenotazioni in sede senza email e test offline eseguibili per backup cifrato e pacchetto deterministico. Le attività residue richiedono un ambiente WordPress o decisioni del gestore:

1. installare e collaudare la 9.4.4 su staging con la matrice dei ruoli;
2. limitare enumerazione utenti e valutare XML-RPC con procedura antilockout;
3. proteggere `wp-config.php`, disabilitare editor file e rimuovere `readme.html` ;
4. applicare WAF in monitoraggio, poi enforcement graduale;
5. testare concorrenza, cache/CDN, backup, privacy, cron e rollback nel WordPress reale;
6. eseguire vulnerability assessment dell'intera installazione e penetration test autorizzato prima o subito dopo il go-live controllato.

## 15. Storico sintetico del progetto

- **8.7.1-8.8.1:** protezione endpoint GDPR, rimozione PII dai debug, retention, IP, informativa e contatti RPD.
- **9.0.0:** migrazione del personale in `wp-admin`, ruoli/capability, bundle separati, strumenti privacy e step-up.
- **9.0.1-9.0.7:** hardening anti-abuso e proxy, concorrenza, import Excel, SMTP, accessibilità stato, minimizzazione catalogo pubblico, countdown e feedback.
- **9.1.0-9.1.3:** log e statistiche, whitelist/blacklist, PDF completi, aggiornamenti di disponibilità e preservazione delle impostazioni.
- **9.2.0-9.2.3:** paginazione e ricerca globale, export log/statistiche, backup/ripristino, grafici e filtri prenotazioni.
- **9.3.0-9.3.2:** indirizzo strutturato, prenotazioni in sede, reinvio email, logo, validazione UI e import con prenotazioni attive.
- **9.4.0-9.4.2:** strumenti completi per interessati, blacklist strutturata, backup cifrato, cleanup verificabile, regola email/domicilio per origine e correzione del payload OTP online.

- **9.4.3:** hardening cache privata e capability privacy, logout per account, backup legacy fail-closed e ZIP ripetibile con controllo artefatti sensibili.

Documento interno di lavoro · 20/08/2026

- **9.4.4:** ripristino delle prenotazioni in sede senza email, test offline della cifratura e verifica byte-per-byte del pacchetto e del manifesto interno.

Lo storico deriva dai commenti di versione e dai piani tecnici del repository; non sostituisce un registro formale delle modifiche firmato o un inventario Git completo.

## 16. Evidenze da consegnare allo specialista

- ZIP esatto della versione installata e relativo SHA-256;
- questo dossier, piano operativo e informativa corrente;
- schema ruoli/capability e elenco account assegnati, senza password;
- screenshot delle impostazioni privacy/retention, diagnostica e ultimo cleanup;
- lista completa e versioni di WordPress, tema, plugin, PHP, Apache e database;
- configurazione WAF/proxy/cron redatta senza segreti;
- esempi anonimizzati di log, export interessato, email e PDF;
- risultato di backup/ripristino su staging;
- esiti test anonimo/Operatore/Responsabile/amministratore;
- contratti e ruoli dei fornitori, tempi dei backup hosting e log esterni;
- decisioni del Titolare e parere del RPD;
- registro dei rischi accettati e responsabili delle azioni.

## 17. Approvazioni

| Ruolo                     | Nome | Data | Esito/firma |
|---------------------------|------|------|-------------|
| Referente del servizio    |      |      |             |
| Responsabile IT/hosting   |      |      |             |
| Titolare o delegato       |      |      |             |
| RPD/DPO                   |      |      |             |
| Responsabile del collaudo |      |      |             |

**Classificazione proposta:** documento interno di lavoro; distribuire solo ai soggetti coinvolti nell'analisi e rimuovere eventuali allegati contenenti dati reali prima della trasmissione.